

Caso de estudio 2 - Actividad resuelta (Clase 8)

Contenido

Contenido	1
Caso de estudio	2
Tipo de incidente: Denegación de servicio (DoS)	2
Inicio del incidente	2
Detalles del ataque	2
Trabajo:	2
Requerimientos	2
Indicaciones:	3
Cuestionario guía	3
Nota:	3
Respuesta	4
Análisis inicial	4
Posibles aberturas a analizar	4
Orden de prioridades a analizar	5
Diagrama de ataque	5
Anexo	6
Cyber Kill Chain	6
Timeline de Incidente x Matriz de roles	6
Boceto superficial	7

Caso de estudio

Tipo de incidente: Denegación de servicio (DoS)

Inicio del incidente

El viernes **23 de diciembre de 2018** una Empresa de Retail fue atacada por un intruso que impidió la continuidad del negocio en sus casi 120 sucursales.

Detalles del ataque

Iniciado entre los días 23 y 30 de diciembre de 2018, se repitió cada 2 días, a veces con cuatro y cinco ataques diarios, hasta arremetió también contra los proveedores que dan soporte a la red de las sucursales. Llegó a afectar en algunos momentos al 90% de los usuarios.

En un análisis preliminar de la situación determinó que un intruso había dejado un programa que se ejecutó el viernes a las 19:00hs horas y que bloqueaba el acceso al sistema de Ventas de todas las sucursales. Se comenzó a trabajar en dos líneas: Volver a la operación normal. Detección, análisis y rastreo del intruso.

Trabajo:

Requerimientos

1. Plantee la metodología de Investigación.
2. Cuáles fueron los resultados obtenidos.

Indicaciones:

En base a sus conocimientos identifique los siguientes factores y trate de establecer una línea de trabajo contestando el siguiente cuestionario guía.

Cuestionario guía

1. ¿Qué información puede obtener Ud del caso de estudio?
2. ¿Se puede identificar el origen del ataque? Lugar, hora, precedencia, etc. Justifique
3. ¿Qué tipo de ataque realizó? Clasifique el mismo
4. ¿Qué vulnerabilidades aprovechó el atacante? ¿De la persona o empresa?
5. ¿Qué técnicas empleó?
6. ¿Desde dónde cree Ud que el atacante realizó la acción?
7. ¿Qué medidas preventivas se pueden adoptar ante estas prácticas delictivas?
8. ¿Se puede identificar al atacante? Nombre, apellido, datos personales, etc

Nota:

El cuestionario, como se indicó, es una “guía”.

No debe contestarse en el orden estricto en el que está y se puede agregar toda información que crea conveniente.

Respuesta

Análisis inicial

Posibles aberturas a analizar

Credenciales y accesos remotos

Lo más probable, por la forma en que el ataque fue repetitivo y programado, es que alguien con acceso válido (o que obtuvo credenciales de alguien que lo tenía) haya instalado el programa malicioso.

- Esto apunta a un acceso remoto o proveedor comprometido antes que a un empleado común de sucursal.
- Revisar los logs de VPN/RMM y las cuentas de proveedor sería lo primero que haría, porque si esas credenciales siguen activas, el atacante puede volver a entrar.

Tareas programadas y binarios en las sucursales

Dado que el ataque se dispara a la misma hora y se repite, casi seguro hubo persistencia instalada (tarea programada o servicio, como un cron job).

- Analizar una sucursal afectada para confirmar si existe esa tarea o binario, y desde qué usuario se creó.
- Esto te puede dar el nombre de la cuenta usada y te ayuda a trazar hacia atrás el origen.

Posible participación de un empleado (insider)

Aunque es posible que alguien interno haya sido el responsable, es menos probable que un empleado promedio logre coordinar un ataque tan distribuido y repetitivo.

- Recién analizaría esto si los accesos externos y de proveedor no explican el caso.

Alumno: Luciano Esteban | **Materia:** Seguridad Informática
Año: 2025 | **Carrera:** ININF | **Profesor:** Gabriel Vicente López

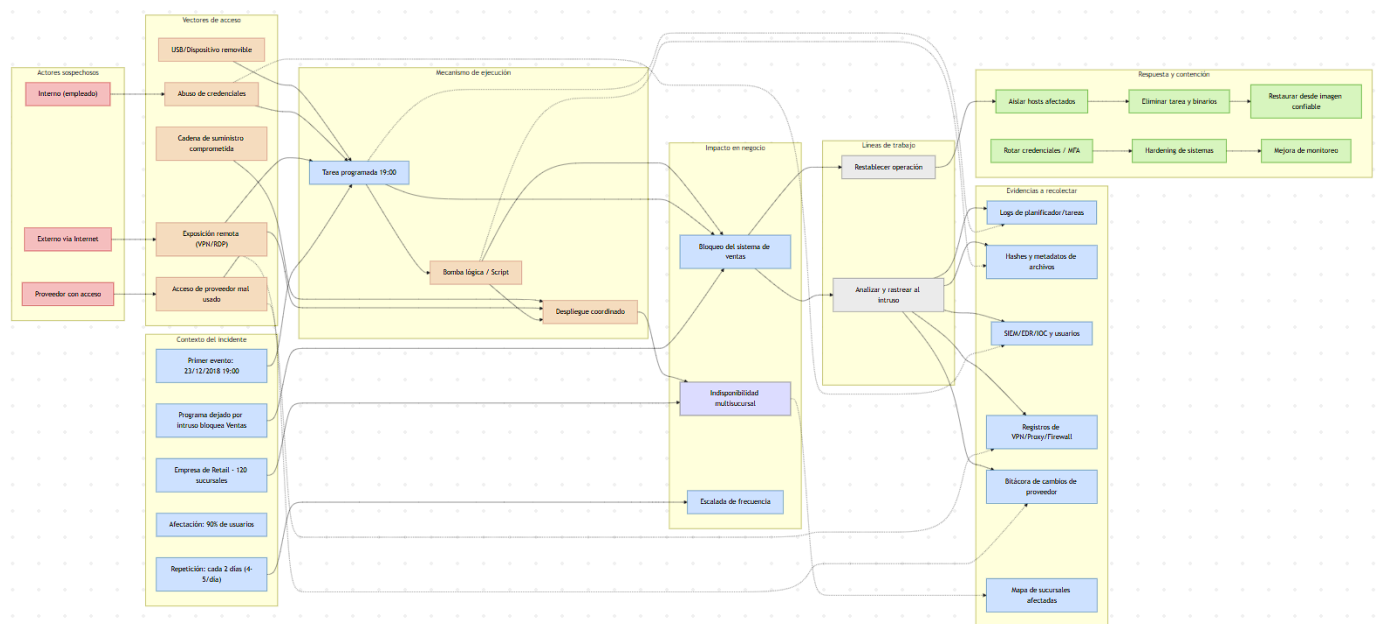
Pruebas de descarga maliciosa o phishing

Revisar si hubo correos sospechosos o descargas de internet que hayan traído el malware, pero lo pondría en tercer lugar: el patrón de ataque parece más orquestado que un simple click en un adjunto.

Orden de prioridades a analizar

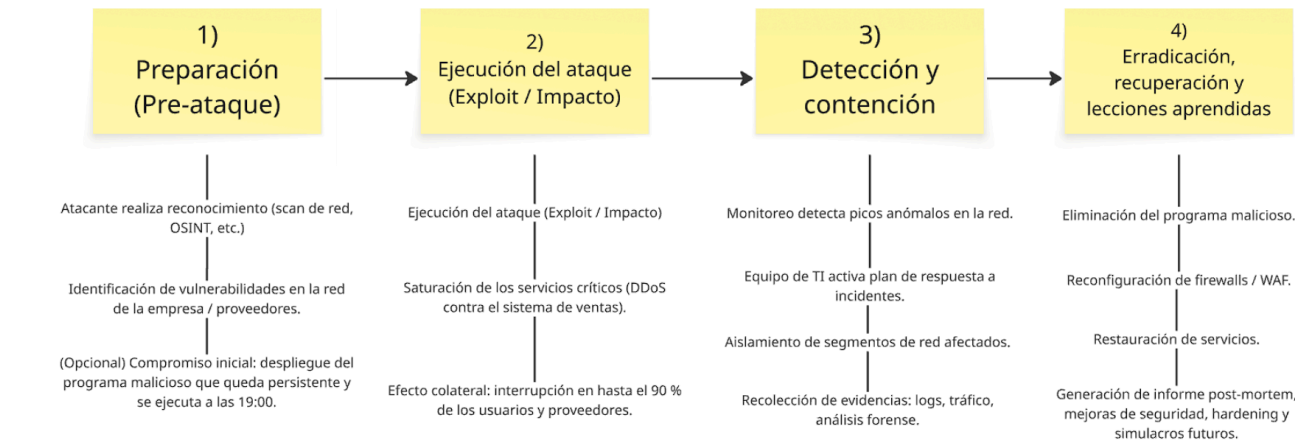
- **Prioridad alta:** revisar credenciales y accesos remotos de proveedores/usuarios privilegiados y confirmar la existencia de tareas programadas.
- **Prioridad media:** investigar descargas o phishing que pudieran haber dejado el binario.
- **Prioridad baja (último recurso):** hipótesis de insider puro (empleado actuando intencionalmente), salvo que la evidencia apunte en esa dirección.

Diagrama de ataque

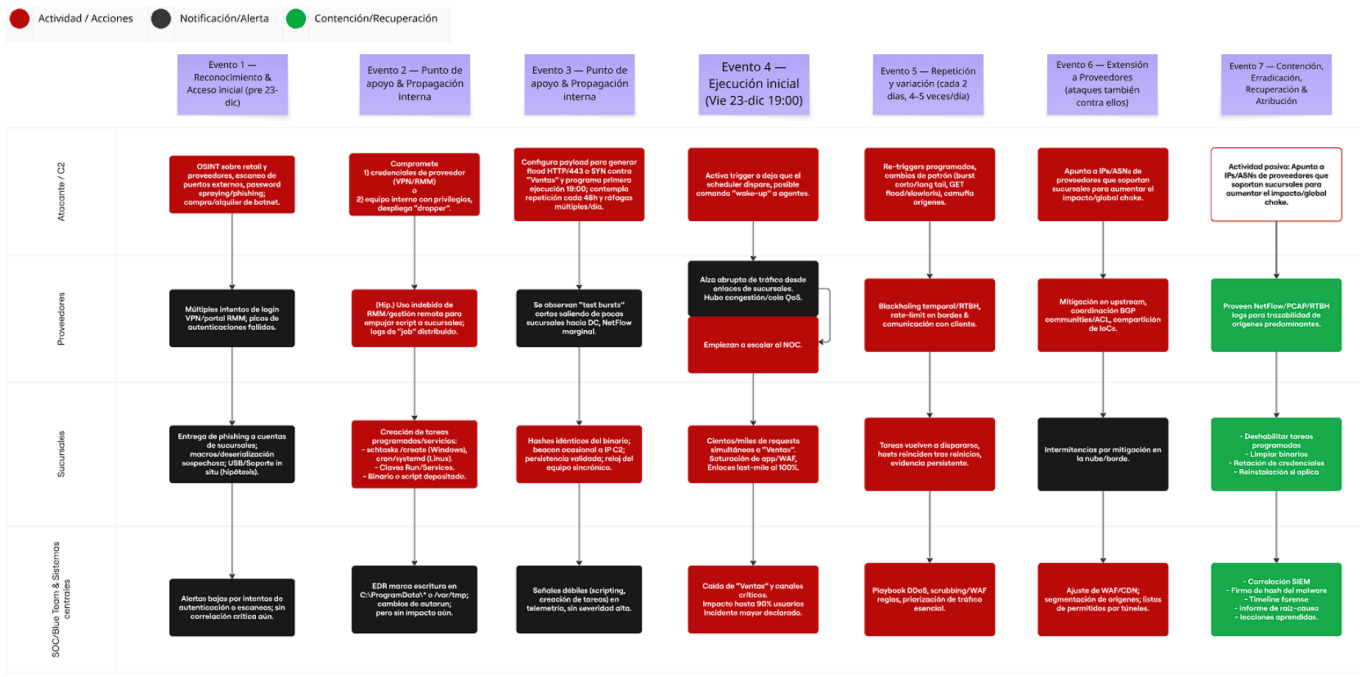


Anexo

Cyber Kill Chain



Timeline de Incidente x Matriz de roles



Boceto superficial

